

Sorso

Come attivare l'API e lo spazio di team

Una guida breve per chi gestisce il sito partner: cosa ci devi mandare, cosa ricevi e come provare che tutto funziona prima di andare online.

Versione di Sorso	1.4.0 — ultimo aggiornamento: 8 ottobre 2026
Indirizzo di Sorso	https://sorso-taccuino.vercel.app
Tempo necessario	circa mezza giornata di lavoro per chi sviluppa il sito; l'attivazione da parte nostra richiede pochi minuti

In breve: quattro passi

Passo	Chi	Cosa
1. Richiesta	Tu	Ci mandi i dati del tuo sito (elenco qui sotto).
2. Attivazione	Noi	Creiamo il tuo spazio e ti consegniamo ID partner, segreto di firma e chiave API, in due invii separati.
3. Prova	Tu	Provi la chiave con un comando e apri lo spazio da una pagina di prova.
4. Messa online	Tu + noi	Spunti l'elenco di verifica; se serve aggiustiamo domini, colori e lingua.

Passo 1 — cosa ci devi mandare

Dato	Esempio e note
Nome del sito o del club	«Enoteca Ruggeri». Compare come titolo in alto nello spazio.
Domini che incorporeranno lo spazio	Con <code>https://</code> , senza percorso: <code>https://www.enotecaruggeri.example</code> . Se hai un sito di prova e uno vero, mandaci entrambi. Da qualunque altro dominio il browser blocca la pagina.
Lingua	Italiano, inglese, o scelta per utente (nel token).
Logo e colori	Indirizzo <code>https</code> di un'immagine; colore d'accento, sfondo e testo in formato <code>#rrggbb</code> . I colori vengono corretti da noi se il testo non fosse leggibile.
Modalità di voto	Voto rapido (occhio, naso, bocca da 50 a 100), scheda completa, o entrambe; quale proporre per prima.
Ruoli e gruppi	Chi è organizzatore sul tuo sito e come raggruppi le persone in team (stesso team = stesse degustazioni).
Chi riceve le credenziali	Un riferimento tecnico, con un canale sicuro (non l'email in chiaro).

Passo 2 — cosa ricevi

Credenziale	A cosa serve	Dove tenerla
ID partner enoteca-ruggeri	Identifica il tuo sito. Va nell'indirizzo dell'iframe e nel claim iss del token.	Non è segreto.
Segreto di firma 64 caratteri	Con questo il tuo server firma il token di ogni utente (HS256).	Solo sul server, in una variabile d'ambiente. Mai nel browser, mai nel codice.
Chiave API sk_...	Legge i risultati dal tuo server (sola lettura).	Solo sul server. Se pensi sia stata esposta, chiedi subito la rotazione (vale entro 60 secondi).

Il segreto e la chiave ti vengono mostrati una volta sola e li riceverai in due invii separati. Conservali subito in un gestore di segreti. Se li perdi non si possono rileggere: se ne genera una coppia nuova.

Passo 3 — prova in cinque minuti

Prova A: la chiave API. Da un terminale del tuo server (sostituisci la chiave):

```
curl -sS -H 'Authorization: Bearer sk_ID_PARTNER_...' \
https://sorso-taccuino.vercel.app/api/v1/tastings
```

Se è tutto a posto la risposta è un elenco, all'inizio vuoto: {"tastings": []}. Con 401 la chiave non è giusta o è stata ruotata.

Prova B: lo spazio di team. Firma un token con uno degli esempi della guida completa (Node, Python o PHP, in docs/esempi/) e apri questa pagina in un iframe del tuo sito di prova. Il token va **dopo il #**:

```
https://sorso-taccuino.vercel.app/embed?p=ID_PARTNER#token=TOKEN_FIRMATO
```

Un utente con role: "organizer" vede «Nuova degustazione»; uno con member no. Il token è monouso e dura al massimo 15 minuti: generane uno nuovo a ogni caricamento della pagina.

Se qualcosa non va

Cosa vedi	Causa probabile	Cosa fare
Iframe vuoto o errore del browser	Il dominio della pagina non è tra quelli registrati.	Mandaci il dominio esatto.
«L'accesso non è valido o è scaduto»	Token firmato col segreto sbagliato, scaduto o con campi mancanti.	Controlla iss, sub, team, jti, exp (guida completa, capitolo 3).
«Questo accesso è già stato usato»	Lo stesso token è arrivato due volte (pagina in cache, anteprima automatica).	Un token nuovo a ogni caricamento; niente cache sulla pagina.
401 dall'API	Chiave sbagliata o ruotata.	Verifica la chiave; se serve, chiedine una nuova.

Passo 4 — elenco di verifica prima di andare online

Verifica

- ☐ ID partner, segreto e chiave sono salvati solo sul server.
- ☐ L'iframe si apre dai tuoi domini e viene bloccato da altri.
- ☐ Il token è generato a ogni caricamento, e la pagina non è in cache.
- ☐ Un partecipante vota e vede la media del team solo dopo.
- ☐ Un organizzatore crea una degustazione, aggiunge vini e la chiude.
- ☐ La lettura dei risultati dal server funziona (JSON e CSV).
- ☐ Sai chi, da te, gestisce le richieste di cancellazione dei dati degli utenti (c'è l'API apposta).
- ☐ Scarichi il CSV dei risultati al termine di ogni degustazione: il servizio è gratuito e non ha garanzia di continuità.

Dopo l'attivazione puoi chiederci in qualsiasi momento: un nuovo dominio, un cambio di colori o lingua, la rotazione del segreto o della chiave, la sospensione dello spazio. Per tutti i dettagli tecnici (campi del token, codici d'errore, limiti, privacy) c'è la **guida all'integrazione** completa.